

PS05 – Pre-Audit Self-Assessment: Evaluacion de la Implementacion del SGSI

ID Documento: GOYA-PS05-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Confidencial **Proximo revision:** 2027-03-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Oficial de Seguridad	Documento inicial

1. Control del Documento

1.1 Disclaimer

ESTE DOCUMENTO ES UNA AUTO-EVALUACION PREPARATORIA. NO REEMPLAZA EL INFORME DE AUDITORIA INDEPENDIENTE REQUERIDO POR EA-103 v2.1 SECCION 4.12 (PS05).

La Guia de Acreditacion EA-103 v2.1 exige en su seccion 4.12 que el sub-proceso PS05 sea ejecutado por una entidad auditora externa independiente y calificada. Este documento simula la evaluacion que dicha entidad realizaria, con el proposito de:

- Identificar brechas antes de que el auditor externo las encuentre.
- Reducir el costo y la duracion de la auditoria externa.
- Priorizar las acciones de remediacion.
- Documentar el estado real de la implementacion del SGSI sin sesgos optimistas.

Los hallazgos de este documento no tienen validez ante la Entidad Acreditadora (Subsecretaria de Economia). La acreditacion como PSC bajo Ley 19.799 requiere el informe de un auditor independiente calificado conforme a EA-103 v2.1 seccion 4.12 criterio 1.

1.2 Responsabilidad del documento

Funcion	Nombre	Cargo
Elaboracion	Oficial de Seguridad	

Funcion	Nombre	Cargo
		Oficial de Seguridad de la Informacion
Revision tecnica	Arquitecto de Sistema	Arquitecto Criptografico / Sistema
Aprobacion	Pendiente	Gerente General

1.3 Distribucion

Este documento se clasifica como **Confidencial** y se distribuye al Oficial de Seguridad, Gerencia General, Arquitecto de Sistema y Auditor Interno. Cada receptor debe registrar acuse de recibo.

1.4 Relacion con EA-103 v2.1

Este documento prepara el cumplimiento del sub-proceso PS05 de la Guia de Acreditacion EA-103 v2.1, seccion 4.12. Su dependencia directa es PS04 (Plan del SGSI, GOYA-PS04-001).

Criterio EA-103 4.12	Estado en esta auto-evaluacion
1. Auditoria realizada por entidad externa independiente calificada	No cumplido – este documento es interno
2. Informe confirma que implementacion del SGSI coincide con PS04	Evaluado internamente – seccion 4
3. Riesgos residuales coinciden con niveles de PS01	Evaluado internamente – seccion 4.5
4. Controles de seguridad operativos y efectivos	Evaluado internamente – seccion 5

1.5 Documentos relacionados

ID	Documento	Relacion
GOYA-PS01-001	Plan de Gestion de Riesgos y Amenazas	Niveles de riesgo residual a verificar
GOYA-PS02-001	Politica de Seguridad de la Informacion	Objetivos de seguridad a verificar
GOYA-PS03-001	Plan de Continuidad del Negocio y Recuperacion de Desastres	Procedimientos de continuidad a verificar
GOYA-PS04-001	Plan del SGSI	Documento principal evaluado
GOYA-PS06-001	Plan de Administracion de Llaves Criptograficas	Controles de gestion de claves a verificar
	Certification Practice Statement	Practicas declaradas a verificar

ID	Documento	Relacion
CPS		
v1.0.0		

2. Objetivo

2.1 Proposito

Evaluar el grado de implementacion del Sistema de Gestion de Seguridad de la Informacion (SGSI) de Goya Ledger SpA, tal como esta definido en PS04 (GOYA-PS04-001), para:

1. Determinar el nivel de preparacion para la auditoria externa requerida por EA-103 v2.1 seccion 4.12.
2. Identificar no conformidades mayores que bloquearian la acreditacion como PSC.
3. Identificar no conformidades menores y observaciones que el auditor externo registraria.
4. Generar un plan de remediacion priorizado con estimaciones de esfuerzo y costo.
5. Estimar el plazo realista para solicitar la auditoria externa.

2.2 Alcance de la evaluacion

Esta evaluacion cubre:

- Las clausulas 4 a 10 de ISO/IEC 27001:2022 segun la estructura del SGSI en PS04.
- Los 93 controles de ISO/IEC 27002:2022 listados en la Declaracion de Aplicabilidad (PS04 seccion 8).
- Los documentos PS01 a PS06 del expediente de acreditacion.
- La implementacion tecnica en el codigo fuente y la infraestructura del PSC.

3. Metodologia de Evaluacion

3.1 Marco de referencia

Esta auto-evaluacion sigue los lineamientos de ISO 19011:2018 (Directrices para la auditoria de sistemas de gestion), adaptados al contexto de auto-evaluacion preparatoria.

3.2 Escala de hallazgos

Clasificacion	Codigo	Definicion	Impacto en acreditacion
Conforme	C		Ningun impacto negativo

Clasificacion	Codigo	Definicion	Impacto en acreditacion
Observacion	OBS	El control esta implementado, es efectivo y existe evidencia verificable	El auditor lo registra; no bloquea
		El control funciona pero tiene debilidades menores o falta de formalizacion	
		El control existe parcialmente o la evidencia es insuficiente	
No Conformidad Menor	NCm	El control no esta implementado, esta gravemente deficiente o representa un riesgo critico	El auditor exige accion correctiva con plazo
No Conformidad Mayor	NCM		El auditor puede recomendar no acreditar hasta que se resuelva

3.3 Tipos de evidencia

Tipo	Descripcion	Ejemplo
Documental	Revision de documentos PS01-PS06, CPS, politicas	Existencia y completitud de PS02
Codigo	Inspeccion del codigo fuente del repositorio goya-ledger	Implementacion de ACL, TLS, audit logging
Configuracion	Revision de configuracion de infraestructura y aplicacion	Variables de entorno, Docker Compose, Fly.toml
Registros	Analisis de logs de auditoria y registros operativos	Cadena hash SHA-256, logs estructurados
Entrevista	Verificacion de conocimiento del personal (no realizada en auto-evaluacion)	N/A en este documento
Prueba de control	Ejecucion de controles para verificar funcionamiento	Ejecucion de cargo-audit, verificacion de TLS

3.4 Limitaciones de esta auto-evaluacion

1. No se realizaron entrevistas al personal (la auto-evaluacion no puede verificar competencia ni concientizacion).
 2. No se ejecutaron pruebas de penetracion (requiere equipo especializado).
 3. No se verifico la implementacion fisica en el datacenter de Fly.io (dependencia del SOC 2 del proveedor).
 4. El sesgo de auto-evaluacion es inherente: el evaluador conoce el sistema, lo cual puede generar tanto sobrevaloracion como subvaloracion.
-

4. Evaluacion del SGSI por Clausula ISO 27001

4.1 Contexto de la Organizacion (Clausula 4)

Requisito PS04: Secciones 3.1-3.5 definen contexto interno/externo, partes interesadas, alcance del SGSI y requisitos de seguridad de la informacion.

Elemento	Evidencia	Hallazgo	Detalle
4.1 Comprension de la organizacion y su contexto	PS04 seccion 3.1: factores internos/ externos documentados	C	Contexto PESTLE, entorno regulatorio chileno, amenazas cuanticas
4.2 Comprension de las necesidades y expectativas de las partes interesadas	PS04 seccion 3.2: partes interesadas catalogadas	C	Suscriptores, Entidad Acreditadora, empleados, proveedores
4.3 Determinacion del alcance del SGSI	PS04 seccion 2.2: alcance definido con servicios	C	CA, TSA, OCSP, RA, blockchain BFT, Tauri
4.4 Sistema de gestion de seguridad de la informacion	PS04 completo, ciclo PDCA	OBS	Ciclo PDCA documentado, pero el SGSI no ha completado un ciclo completo (Check y Act sin ejecucion)

Recomendacion: La clausula 4 esta razonablemente cubierta. El auditor verificara que el contexto se actualice periodicamente; actualmente no hay evidencia de una primera revision.

4.2 Liderazgo (Clausula 5)

Requisito PS04: Secciones 4.1-4.3 definen compromiso de la direccion, politica y roles.

Elemento	Evidencia	Hallazgo	Detalle
5.1 Liderazgo y compromiso	PS02 seccion 2: Declaracion de la Direccion firmada	NCM	Todos los documentos PS01-PS06 tienen estado “Borrador” y aprobacion “Pendiente – Gerencia General”. No existe firma de la direccion en ningun documento del SGSI.
5.2 Politica	PS02 completo	NCm	Politica documentada pero sin firma de aprobacion de la direccion
5.3 Roles, responsabilidades y autoridades	PS02 seccion 7, PS04 seccion 4.3	OBS	Roles definidos documentalmente. Sin evidencia de comunicacion formal al personal ni de aceptacion de responsabilidades

Recomendacion: La falta de aprobacion formal de la direccion en todos los documentos PS es una **no conformidad mayor critica**. Un auditor externo detendra la evaluacion en este punto. La direccion debe firmar todos los documentos antes de solicitar la auditoria.

4.3 Planificacion (Clausula 6)

Requisito PS04: Secciones 5.1-5.2 vinculan riesgos PS01 con controles y objetivos PS02.

Elemento	Evidencia	Hallazgo	Detalle
6.1 Acciones para abordar riesgos y oportunidades	PS01 con 35 riesgos catalogados, PS04 SoA con 91 controles aplicables	C C	Vinculacion riesgo-control documentada

Elemento	Evidencia	Hallazgo	Detalle
6.2 Objetivos de seguridad y planificacion	PS02 seccion 5.1: 10 objetivos OS-01 a OS-10 con KPIs	C	Objetivos medibles con umbrales
6.3 Planificacion de cambios	PS04 seccion 14: ciclo de revision y eventos disparadores		Proceso de cambios documentado

Recomendacion: Planificacion solida en papel. El auditor verificara que los KPIs se midan efectivamente (ver clausula 9).

4.4 Soporte (Clausula 7)

Requisito PS04: Secciones 6.1-6.3 definen recursos, competencia y concientizacion.

Elemento	Evidencia	Hallazgo	Detalle
7.1 Recursos	PS04 seccion 6.1: recursos y capacidades definidos	OBS	Recursos documentados, presupuesto de seguridad referenciado pero sin cifras concretas
7.2 Competencia	PS04 seccion 6.2: requisitos de competencia por rol	NCm	Requisitos de competencia definidos pero sin evidencia de evaluacion de competencia del personal actual, sin registros de formacion
7.3 Concientizacion	Control 6.3 planificado	NCM	No existe programa de concientizacion en seguridad. Todo el personal deberia conocer la politica de seguridad (PS02) y su rol en el SGSI. Sin evidencia de que el personal haya leído o comprendido PS02.

Elemento	Evidencia	Hallazgo	Detalle
7.4 Comunicacion	PS04 seccion 6.3: plan de comunicacion	NCm	Plan de comunicacion documentado pero sin evidencia de ejecucion, sin registros de distribucion de PS02 al personal
7.5 Informacion documentada	PS01-PS06, CPS documentados	OBS	Documentacion extensa pero sin control de distribucion implementado (acuse de recibo pendiente)

Recomendacion: Soporte es un area debil. El programa de concientizacion es un requisito ineludible de ISO 27001. La falta total de evidencia de formacion es una NC mayor que el auditor externo registrara.

4.5 Operacion (Clausula 8)

Requisito PS04: Secciones 7-11 definen controles operativos, gestion de riesgos y relaciones con proveedores.

Elemento	Evidencia	Hallazgo	Detalle
8.1 Planificacion y control operacional	PS04 SoA, controles tecnologicos implementados	OBS	42 de 91 controles aplicables implementados (46%). El plan operacional existe pero la implementacion esta incompleta
8.2 Evaluacion de riesgos de seguridad	PS01 con metodologia ISO 27005 + NIST 800-30	C	Evaluacion de riesgos completa con 35 riesgos catalogados
8.3 Tratamiento de riesgos	PS01 seccion 6 con planes de tratamiento, PS04 SoA	NCm	Planes de tratamiento definidos para todos los riesgos, pero 19 controles estan en estado "Planificado"

Elemento	Evidencia	Hallazgo	Detalle
			(no implementados). Los riesgos que dependen de esos controles no estan tratados efectivamente

Recomendacion: La operacion del SGSI muestra progreso significativo en controles tecnologicos pero rezago en controles de personas y procesos. El nivel de riesgo residual declarado en PS01 no se alcanza en la practica para riesgos tratados por controles no implementados.

4.6 Evaluacion del Desempeno (Clausula 9)

Requisito PS04: Seccion 12 define monitoreo, auditoria interna y revision por la direccion.

Elemento	Evidencia	Hallazgo	Detalle
9.1 Monitoreo, medicion, analisis y evaluacion	PS04 seccion 12.1: 10 KPIs definidos con umbrales	NCM	KPIs definidos pero sin evidencia de medicion. No existen dashboards, reportes ni registros historicos de medicion de KPIs. El monitoreo existe a nivel de health endpoint pero no como proceso SGSI. No se ha ejecutado ninguna auditoria interna del SGSI. El calendario inicia en 2027-Q1, lo que significa que el SGSI no tiene evidencia de ciclo Check.
9.2 Auditoria interna	PS04 seccion 12.2: programa de auditoria definido	NCM	

Elemento	Evidencia	Hallazgo	Detalle
9.3 Revision por la direccion	PS04 seccion 12.3: agenda y contenido definidos	NCM	No se ha ejecutado ninguna revision por la direccion. Sin acta de revision, sin aprobacion de nivel de riesgo residual, sin asignacion formal de recursos.

Recomendacion: La clausula 9 es la mas deficiente. Un auditor externo requerira al menos un ciclo de auditoria interna y una revision por la direccion antes de que el SGSI pueda considerarse operativo. Esto es un bloqueador de acreditacion.

4.7 Mejora (Clausula 10)

Requisito PS04: Seccion 13 define proceso de no conformidades y mejora continua.

Elemento	Evidencia	Hallazgo	Detalle
10.1 No conformidad y accion correctiva	PS04 seccion 13.1: proceso con plazos definidos	NCm	Proceso documentado pero no probado. No existen registros de no conformidades porque no se ha ejecutado auditoria interna. El proceso existe en papel pero no hay evidencia de operacion
10.2 Mejora continua	PS04 seccion 13.2: fuentes de mejora identificadas	OBS	Proceso definido. Sin evidencia de ejecucion dado que el SGSI esta en fase inicial

Recomendacion: El proceso de mejora continua no puede operar sin los insumos de la clausula 9. Una vez que se ejecute la primera auditoria interna, el proceso de NC/ accion correctiva se activara naturalmente.

5. Evaluacion de Controles ISO 27002:2022

5.1 Resumen Estadistico por Categoria

Datos de la Declaracion de Aplicabilidad (PS04 seccion 8.5):

Categoria	Total	Aplicables	N/A	Implementado	Parcial	Planificado	% Implementado
Organizacional (5.x)	37	37	0	15	15	7	41%
Personas (6.x)	8	8	0	0	2	6	0%
Fisico (7.x)	14	14	0	6	4	4	43%
Tecnologico (8.x)	34	32	2	21	9	2	66%
Total	93	91	2	42	30	19	46%

5.2 Controles Organizacionales (5.x)

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
5.1	Políticas de seguridad	Implementado	OBS	Política documentada (PS02), sin firma de aprobacion	P1
5.2	Roles y responsabilidades	Implementado	OBS	Definidos en PS02 s7, sin comunicacion formal al personal	P2
5.3	Segregacion de funciones	Parcial	NCm	ACL implementado; maker-checker pendiente para emision de certificados	P1
5.4	Responsabilidades de la direccion	Implementado	NCM	Declaracion existe (PS02 s2), sin firma ni evidencia de compromiso activo	P1
5.5	Contacto con autoridades	Planificado	NCm	Sin directorio de contactos de Entidad Acreditadora, CSIRT Chile	P2
5.6	Contacto con grupos de interes	Parcial	OBS	Participacion informal en	P3

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
5.7	Inteligencia de amenazas	Parcial	NCm	comunidades PQC/PKI cargos-audit automatizado, CVE manual. Sin proceso formal con responsable y frecuencia definida	P2
5.8	Seguridad en gestion de proyectos	Parcial	NCm	Proceso informal. Sin checklist de seguridad para cambios al PSC	P2
5.9	Inventario de activos	Implementado	C	PS01 secciones 3.1-3.4 con catalogo completo	—
5.10	Uso aceptable de activos	Planificado	NCm	Sin politica de uso aceptable	P2
5.11	Devolucion de activos	Planificado	NCm	Sin procedimiento de desvinculacion	P2
5.12	Clasificacion de informacion	Implementado	C	4 niveles en PS02 s8.10	—
5.13	Etiquetado de informacion	Parcial	OBS	Documentos PS etiquetados; sistema general pendiente	P3
5.14	Transferencia de informacion	Implementado	C	TLS 1.3, mTLS entre nodos	—
5.15	Control de acceso	Implementado	C	ACL deny-by-default, enforce_acl	—
5.16	Gestion de identidades	Parcial	NCm	DIDs para sistemas; gestion de identidad de personal no formalizada	P2
5.17	Informacion de autenticacion	Parcial	NCm	Smart-ID operativo; ClaveUnica pendiente; autenticacion	P1

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
5.18	Derechos de acceso	Parcial	NCm	de operadores sin MFA ACL implementado; revision trimestral de accesos pendiente	P2
5.19	Seguridad con proveedores	Planificado	NCM	Sin evaluacion de seguridad de Fly.io ni de otros proveedores. No hay clausulas de seguridad en contratos. Sin clausulas de seguridad en acuerdos con proveedores cloud.	P1
5.20	Acuerdos con proveedores	Planificado	NCM		P1
5.21	Cadena de suministro TIC	Parcial	NCm	cargo-audit y versiones fijadas; SBOM pendiente	P2
5.22	Monitoreo de proveedores	Planificado	NCm	Sin proceso de revision periodica de proveedores	P2
5.23	Servicios cloud	Parcial	NCm	TLS y aislamiento; evaluacion formal de SOC 2 de Fly.io pendiente	P1
5.24	Gestion de incidentes (planificacion)	Implementado	C	PS07 documentado	—
5.25	Evaluacion de eventos	Implementado	C	Clasificacion P1-P4	—
5.26	Respuesta a incidentes	Implementado	OBS	Procedimientos documentados, sin simulacro ejecutado	P2
5.27	Aprendizaje de incidentes	Implementado	OBS	Procedimiento post-mortem definido, sin	P3

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
5.28	Recopilacion de evidencia	Parcial	NCm	ejecucion (no ha habido incidentes) Logs append-only; procedimiento forense formal pendiente	P2
5.29	Seguridad durante disrupcion	Implementado	C	PS03 documentado	—
5.30	Preparacion TIC para continuidad	Implementado	NCm	PS03 con RTO/RPO definidos pero sin prueba de recuperacion ejecutada	P1
5.31	Requisitos legales	Implementado	C	Marco regulatorio completo en PS02 s4	—
5.32	Propiedad intelectual	Parcial	OBS	Cargo.lock con licencias; politica formal de PI pendiente	P3
5.33	Proteccion de registros	Implementado	C	Cadena hash SHA-256 append-only	—
5.34	Privacidad y PII	Parcial	NCm	Cifrado en transito; cifrado en reposo y politica de retencion pendientes	P1
5.35	Revision independiente	Planificado	NCM	Sin auditoria externa realizada. Primera planificada 2027-Q2.	P1
5.36	Cumplimiento con politicas	Parcial	NCm	CI/CD verifica estandares tecnicos; auditoria interna de procesos pendiente	P2
5.37	Procedimientos operacionales	Parcial	NCm	Documentos PS criticos	P2

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
				existen; procedimientos operativos detallados en desarrollo	

5.3 Controles de Personas (6.x)

Esta es la categoria mas debil del SGSI. Ningun control esta implementado.

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
6.1	Seleccion	Planificado	NCM	Sin procedimiento de seleccion ni verificacion de antecedentes. Personal con acceso a claves CA sin background check documentado.	P1
6.2	Terminos y condiciones de empleo	Planificado	NCM	Sin clausulas de seguridad en contratos laborales. Personal sin obligaciones formales de confidencialidad en el contexto del SGSI.	P1
6.3	Concientizacion y formacion	Planificado	NCM	Sin programa de concientizacion. Sin registros de formacion en seguridad. Personal puede no conocer la politica de seguridad PS02.	P1
6.4	Proceso disciplinario	Planificado	NCm	Sin politica disciplinaria para violaciones de seguridad	P2
6.5	Responsabilidades post-empleo	Planificado	NCm	Sin procedimiento de desvinculacion.	P1

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
6.6	Acuerdos de confidencialidad	Planificado	NCM	Accesos podrian no revocarse al termino del empleo Sin NDAs firmados. Personal con acceso a claves y datos criticos del PSC sin obligacion legal de confidencialidad documentada.	P1
6.7	Trabajo remoto	Parcial	NCm	VPN y SSH con clave publica implementados; politica formal de trabajo remoto pendiente	P2
6.8	Reportes de eventos de seguridad	Parcial	NCm	Procedimiento informal existente; canal formal pendiente	P2

5.4 Controles Fisicos (7.x)

La operacion en la nube (Fly.io) reduce la superficie de controles fisicos propios pero introduce dependencia del proveedor.

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
7.1	Perimetros de seguridad fisica	Implementado	OBS	Delegado a Fly.io via SOC 2. Verificar que el informe SOC 2 de Fly.io este disponible y vigente	P2
7.2	Controles de entrada fisica	Implementado	OBS	Delegado a Fly.io via SOC 2. Misma observacion	P2
7.3	Seguridad de oficinas	Planificado	OBS	PSC opera remotamente. Si se establecen oficinas, controles requeridos. Documentar	P3

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
7.4	Vigilancia de seguridad fisica	Parcial	NCm	decision de operacion remota Datacenter cubierto via Fly.io; custodia de fragmentos M-of-N sin controles definidos	P1
7.5	Amenazas fisicas y ambientales	Implementado	OBS	Delegado a Fly.io via SOC 2	P2
7.6	Trabajo en areas seguras	Planificado	NCM	Sin procedimiento de ceremonia de claves en area controlada. La ceremonia de claves es un evento critico para un PSC que requiere controles fisicos estrictos.	P1
7.7	Escritorio limpio / pantalla limpia	Planificado	NCm	Sin politica. Riesgo medio dado el trabajo remoto	P3
7.8	Ubicacion y proteccion de equipos	Parcial	NCm	Equipos de ceremonia offline, almacenamiento formal pendiente	P2
7.9	Seguridad de activos fuera de instalaciones	Parcial	NCm	Fragmentos M-of-N distribuidos; custodia formal pendiente	P1
7.10	Medios de almacenamiento	Parcial	NCm	Zeroizacion en software; destruccion de medios fisicos pendiente	P2
7.11	Servicios de soporte	Implementado	C	Fly.io proporciona redundancia	—

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
7.12	Seguridad del cableado	Implementado	C	Delegado a Fly.io	—
7.13	Mantenimiento de equipos	Implementado	C	Fly.io gestiona mantenimiento	—
7.14	Eliminacion segura de equipos	Planificado	NCm	Sin procedimiento de destruccion segura	P2

5.5 Controles Tecnologicos (8.x)

Categoria con mayor nivel de implementacion, reflejando la fortaleza tecnica del equipo.

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
8.1	Dispositivos de punto final	Parcial	NCm	Tauri sandboxed; politica de endpoints de administracion pendiente	P2
8.2	Acceso privilegiado	Implementado	C	ACL deny-by-default, enforce_acl, roles diferenciados	—
8.3	Restriccion de acceso a informacion	Implementado	C	Channels, ACL por endpoint	—
8.4	Acceso a codigo fuente	Implementado	C	Control de acceso del repositorio Git	—
8.5	Autenticacion segura	Implementado	OBS	mTLS para nodos, SSH para admin, JWT para API. Sin MFA para operadores	P2
8.6	Gestion de capacidad	Parcial	NCm	Monitoreo basico; alertas automaticas pendientes	P2
8.7	Proteccion contra malware	Implementado	C	Rust memory safety, Wasm sandbox	—
8.8	Gestion de vulnerabilidades	Parcial	NCm	cargo-audit implementado; SLA de remediacion sin definir	P2
8.9	Gestion de configuracion	Implementado	C	Variables de entorno documentadas, RUST_BC_ENV	—
8.10	Eliminacion de informacion	Planificado	NCm	Zeroizacion de claves implementada; eliminacion de datos de registro pendiente	P2
8.11	Enmascaramiento de datos	Parcial	NCm	Logs sin PII; enmascaramiento sistematico pendiente	P2
8.12		Parcial	NCm		P2

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
	Prevenccion de fuga de datos			ACL y aislamiento; monitoreo de exfiltracion pendiente	
8.13	Respaldo de informacion	Implementado	C	Checkpoints RocksDB, replicas BFT, respaldos off-site	—
8.14	Redundancia	Implementado	C	Consenso BFT tolera f fallas	—
8.15	Registro de eventos	Implementado	C	Cadena hash SHA-256 append-only, AuditAction por operacion	—
8.16	Monitoreo de actividades	Parcial	NCm	Health endpoint activo; dashboards y alertas automaticas pendientes	P2
8.17	Sincronizacion de relojes	Implementado	C	NtpTimeSource::validate(), multiples servidores NTP	—
8.18	Programas utilitarios privilegiados	Parcial	OBS	SSH restringido; inventario de utilidades pendiente	P3
8.19	Instalacion de software en produccion	Implementado	C	CI/CD pipeline, revision de codigo	—
8.20	Seguridad de redes	Implementado	C	mTLS, TLS 1.3, verificacion de firma en gossip	—
8.21	Seguridad de servicios de red	Implementado	C	Fly.io edge, rate limiting, CORS	—
8.22	Segregacion de redes	Implementado	C	Red BFT privada, solo API Gateway expuesto	—
8.23	Filtrado web	N/A	C	Justificacion valida: servidores sin navegador	—
8.24	Uso de criptografia	Implementado	C	ML-DSA-65, Ed25519, SHA-256, TLS 1.3, pqc_crypto_module	—
8.25	Ciclo de vida de desarrollo seguro	Implementado	C	CI/CD con fmt/clippy/test, crypto_boundary test	—
8.26	Requisitos de seguridad de aplicaciones	Implementado	C	Middleware de validacion, rate limiting, ApiResponse	—
8.27	Principios de ingenieria segura	Implementado	C	Defensa en profundidad, modulo criptografico centralizado	—
8.28	Codificacion segura	Implementado	C	Rust memory safety, clippy -D warnings	—
8.29	Pruebas de seguridad	Parcial	NCm	Tests unitarios/integracion; pruebas de penetracion pendientes	P1

Control	Nombre	Estado SoA	Hallazgo	Brecha	Prioridad
8.30	Desarrollo externalizado	N/A	C	Desarrollo interno	–
8.31	Separacion de ambientes	Implementado	C	RUST_BC_ENV, Docker Compose por ambiente	–
8.32	Gestion de cambios	Parcial	NCm	CI/CD implementado; CAB formal pendiente	P2
8.33	Informacion de prueba	Implementado	C	tempfile::TempDir, datos sinteticos	–
8.34	Proteccion durante pruebas de auditoria	Planificado	NCm	Procedimiento de auditoria con restricciones pendiente	P3

6. Evaluacion de Documentacion PS

6.1 PS01 – Plan de Gestion de Riesgos y Amenazas

Criterio	Hallazgo	Detalle
Compleitud	C	35 riesgos catalogados, metodologia ISO 27005 + NIST 800-30, valoracion cuantitativa
Cobertura de riesgos	C	Cubre amenazas criptograficas, operacionales, legales, de personal y fisicas
Vinculacion riesgo-control	C	Cada riesgo referencia controles de tratamiento y control SoA
Nivel de riesgo residual	NCm	Niveles de riesgo residual definidos, pero dependen de controles que estan en estado “Planificado”. El riesgo residual real es mayor al declarado
Aprobacion	NCM	Estado “Borrador”, aprobacion “Pendiente – Gerencia General”

Hallazgo global PS01: NCM – Documento tecnico solido, bloqueado por falta de aprobacion formal.

6.2 PS02 – Politica de Seguridad de la Informacion

Criterio	Hallazgo	Detalle
Estructura	C	Cubre todos los elementos requeridos por EA-103 seccion 4.9
Objetivos de seguridad	C	10 objetivos medibles (OS-01 a OS-10) con KPIs
Coherencia con CPS	C	Seccion 9 vincula politica con CPS
Coherencia con PS01	C	Objetivos alineados con niveles de riesgo de PS01
Comunicacion al personal	NCM	Sin evidencia de que el personal conozca la politica. Sin registros de distribucion ni acuse de recibo
Aprobacion	NCM	Estado “Borrador”, aprobacion “Pendiente – Gerencia General”

Hallazgo global PS02: NCM – Contenido completo, dos bloqueadores: aprobacion y comunicacion.

6.3 PS03 – Plan de Continuidad del Negocio y Recuperacion de Desastres

Criterio	Hallazgo	Detalle
BIA (Analisis de Impacto al Negocio)	C	Seccion 4 con RTO/ RPO por servicio
Cobertura de escenarios	C	Escenarios de compromiso de clave, falla de infraestructura, desastre natural
Procedimiento de compromiso de clave	C	Seccion 6.3 alineada con ETSI TS 102 042 S7.4.8
Instalaciones alternativas	OBS	Fly.io multi-region referenciado; sin evidencia de configuracion multi-region activa
Pruebas de continuidad	NCM	No se ha ejecutado ningun simulacro de continuidad ni prueba de recuperacion. No

Criterio	Hallazgo	Detalle
Aprobacion	NCM	hay evidencia de que el RTO de 4 horas y RPO de 1 hora sean alcanzables. Un auditor exigira al menos un simulacro documentado. Estado “Borrador”, aprobacion “Pendiente – Gerencia General”

Hallazgo global PS03: NCM – Plan completo en papel; sin prueba de que funcione en la practica.

6.4 PS04 – Plan del SGSI

Criterio	Hallazgo	Detalle
Estructura ISO 27001	C	Clausulas 4-10 cubiertas
Declaracion de Aplicabilidad	C	93 controles evaluados con justificacion por control
Precision del SoA	OBS	Los estados de implementacion parecen razonables segun la inspeccion de codigo, pero no se ha verificado formalmente cada control con evidencia
Ciclo PDCA	NCm	Plan y Do en progreso; Check y Act no ejecutados
Aprobacion	NCM	Estado “Borrador”, aprobacion “Pendiente – Gerencia General”

Hallazgo global PS04: NCM – El plan del SGSI no esta aprobado por la direccion.

6.5 PS06 – Plan de Administracion de Llaves Criptograficas

Criterio	Hallazgo	Detalle
Ciclo de vida completo	C	Generacion, almacenamiento, respaldo, rotacion, destruccion cubiertos

Criterio	Hallazgo	Detalle
Ceremonia de claves	NCM	Procedimiento documentado pero no se ha ejecutado ninguna ceremonia de claves. Sin evidencia de generacion de CA raiz. Sin custodios designados formalmente para fragmentos M-of-N. Sin actas de custodia firmadas.
HSM	NCM	Almacenamiento de claves operativas (K-02, K-03, K-04) en memoria volatil. El objetivo es HSM FIPS 140-3 Nivel 2+ pero esta planificado para 2027-Q1. Un PSC que emite certificados FEA deberia operar con HSM certificado.
Zeroizacion	C	pqc_crypto_module implementa zeroize trait, verificado por test unitario
Compromiso de clave	C	Procedimiento alineado con PS03 seccion 6.3
Aprobacion	NCM	Estado “Borrador”, aprobacion “Pendiente – Gerencia General”

Hallazgo global PS06: NCM – Bloqueadores criticos: ceremonia no ejecutada, HSM no adquirido.

7. Evaluacion Tecnica

7.1 Controles a Nivel deCodigo

Control	Implementacion	Evidencia	Hallazgo
ACL (Control de Acceso)	enforce_acl deny-by-default en todos los endpoints	Codigo fuente src/api/, ACL_MODE	C
TLS	TLS 1.3 obligatorio entre nodos (mTLS), API con TLS	Configuracion de red, codigo P2P	C

Control	Implementacion	Evidencia	Hallazgo
Audit Logging	Cadena hash SHA-256 append-only, AuditAction por operacion	src/audit/, tests de integridad	C
Rate Limiting	RATE_LIMIT_RPS, RPM, RPH configurables por endpoint	Middleware, variables de entorno	C
Crypto Boundary	Modulo pqc_crypto_module centralizado, test crypto_boundary verifica que no hay imports directos de sha2, ed25519_dalek en src/	cargo test –test crypto_boundary	C
Input Validation	Middleware de validacion, ApiResponse con trace ID	src/api/handlers/	C
CORS	CORS_ALLOWED_ORIGINS restrictivo	Configuracion de entorno	C
Firma de gossip	Mensajes P2P firmados y verificados antes de procesamiento	src/network/	C

7.2 Controles de Infraestructura

Control	Implementacion	Evidencia	Hallazgo
Aislamiento de red	Red BFT privada, solo API Gateway expuesto	Arquitectura de red, Fly.io config	C
Redundancia	Consenso BFT 3f+1 tolerante a fallas bizantinas	Codigo de consenso, tests BFT	C
RespalDOS	Checkpoints RocksDB, replicas BFT	Configuracion de almacenamiento	C
Monitoreo	Health endpoint con verificacion de dependencias	src/api/	OBS
Alertas automaticas	No implementadas	–	NCm
Dashboards operativos	No implementados	–	NCm
Pruebas de recuperacion	No ejecutadas	–	NCM
Multi-region	Referenciado en PS03, sin evidencia de configuracion activa	–	NCm

7.3 Gestion de Claves vs PS06

Aspecto	PS06 Plan	Implementacion Real	Hallazgo
Generacion de CA raiz	Ceremonia con testigos, equipo air-gapped	No ejecutada	NCM
Almacenamiento K-01	Fragmentos M-of-N offline distribuidos	No ejecutado (no hay CA raiz generada)	NCM
Almacenamiento K-02, K-03, K-04	HSM FIPS 140-3 Nivel 2+ (objetivo)	Memoria volatil del servidor	NCM
Rotacion de claves	Periodos definidos por tipo de clave	Sin evidencia de rotacion (claves operativas no generadas formalmente)	NCM
Zeroizacion	pqc_crypto_module con zeroize trait	Implementado en codigo	C
Algoritmos	ML-DSA-65 (FIPS 204) para FEA, Ed25519 para FES	Implementado en codigo	C
CSPRNG	/dev/urandom via pqc_crypto_module	Implementado en codigo	C

7.4 Backup y Recuperacion

Aspecto	Estado	Hallazgo
Checkpoints RocksDB	Implementados	C
Replicas BFT	Operativas en desarrollo, probadas 2-nodo	OBS
Respaldos off-site	Referenciados en PS04; sin evidencia de configuracion	NCm
Prueba de restauracion desde backup	No ejecutada	NCM
RTO/RPO validados	No probados	NCM

8. Resumen de Hallazgos

8.1 Registro de Hallazgos

ID	Tipo	Area	Descripcion	Remediacion	Prioridad	Esfuerzo Est.
H-01	NCM	Cl. 5			P1	1 semana

ID	Tipo	Area	Descripcion	Remediacion	Prioridad	Esfuerzo Est.
			Documentos PS01-PS06 sin aprobacion formal de la direccion. Todos en estado “Borrador” con aprobacion “Pendiente”	Revision y firma por Gerente General de todos los documentos PS		
H-02	NCM	Cl. 9	Sin auditoria interna del SGSI ejecutada	Ejecutar primera auditoria interna con auditor calificado	P1	4-6 semanas
H-03	NCM	Cl. 9	Sin revision por la direccion ejecutada	Convocar primera revision por la direccion con agenda PS04 s12.3	P1	1 semana
H-04	NCM	Cl. 7	Sin programa de concientizacion en seguridad. Personal sin formacion documentada	Desarrollar e impartir programa de concientizacion. Registrar asistencia	P1	4-8 semanas
H-05	NCM	6.1	Sin verificacion de antecedentes del personal con acceso a claves	Implementar procedimiento de background check, ejecutar para personal actual	P1	4 semanas
H-06	NCM	6.2	Sin clausulas de seguridad en contratos laborales	Elaborar anexos de seguridad, firmar con todo el personal	P1	2 semanas
H-07	NCM	6.6	Sin NDAs firmados para personal con acceso a datos criticos del PSC	Elaborar NDA, firmar con todo el personal y contratistas	P1	2 semanas
H-08	NCM	PS06	Ceremonia de claves no ejecutada. Sin CA raiz generada formalmente	Preparar y ejecutar ceremonia de claves con testigos calificados	P1	4-8 semanas
H-09	NCM	PS06	HSM no adquirido ni implementado. Claves operativas	Adquirir HSM FIPS 140-3 Nivel 2+, migrar claves operativas	P1	8-16 semanas

ID	Tipo	Area	Descripcion	Remediacion	Prioridad	Esfuerzo Est.
			en memoria volatil			
H-10	NCM	PS03	Sin simulacro de continuidad ni prueba de recuperacion ejecutada	Ejecutar simulacro tabletop y prueba tecnica de recuperacion	P1	2-4 semanas
H-11	NCM	5.19	Sin evaluacion de seguridad de proveedores (Fly.io)	Obtener y revisar SOC 2 de Fly.io, documentar evaluacion	P1	2 semanas
H-12	NCM	5.20	Sin clausulas de seguridad en acuerdos con proveedores cloud	Negociar addendum de seguridad con Fly.io	P1	4 semanas
H-13	NCM	7.6	Sin procedimiento de ceremonia de claves en area controlada	Definir requisitos del area, preparar procedimiento detallado	P1	2 semanas
H-14	NCM	5.35	Sin auditoria externa de seguridad realizada	Contratar auditor externo calificado ISO 27001	P1	8-12 semanas
H-15	NCM	Cl. 9	KPIs de seguridad definidos pero sin medicion. Sin registros historicos	Implementar dashboards y reporte periodico de KPIs	P1	4 semanas
H-16	NCm	5.3	Segregacion de funciones parcial: maker-checker pendiente para emision de certificados	Implementar flujo maker-checker en emision de certificados	P1	2-4 semanas
H-17	NCm	5.17	Autenticacion de operadores sin MFA. ClaveUnica pendiente	Implementar MFA para acceso administrativo	P1	2 semanas
H-18	NCm	8.29	Sin pruebas de penetracion formales	Contratar prueba de penetracion de tercero	P1	4-6 semanas
H-19	NCm	5.5	Sin directorio de contactos de autoridades	Establecer directorio con	P2	1 dia

ID	Tipo	Area	Descripcion	Remediacion	Prioridad	Esfuerzo Est.
			(Entidad Acreditadora, CSIRT)	datos de contacto verificados		
H-20	NCm	5.7	Inteligencia de amenazas sin proceso formal	Formalizar proceso con responsable y frecuencia	P2	1 semana
H-21	NCm	5.8	Gestion de seguridad en proyectos sin checklist formal	Crear checklist de seguridad para cambios al PSC	P2	1 semana
H-22	NCm	5.10	Sin politica de uso aceptable de activos	Elaborar y comunicar politica	P2	1 semana
H-23	NCm	5.11	Sin procedimiento de desvinculacion	Elaborar procedimiento de offboarding con revocacion de accesos	P2	1 semana
H-24	NCm	5.16	Gestion de identidad de personal no formalizada	Implementar directorio de identidades del personal con revision periodica	P2	2 semanas
H-25	NCm	5.18	Revision trimestral de derechos de acceso pendiente	Programar y ejecutar primera revision de accesos	P2	1 semana
H-26	NCm	5.21	SBOM (Software Bill of Materials) pendiente	Generar SBOM con cargo-sbom o equivalente	P2	1 dia
H-27	NCm	5.23	Evaluacion formal de SOC 2 de Fly.io pendiente	Solicitar y revisar informe SOC 2	P2	2 semanas
H-28	NCm	5.28	Procedimiento forense formal pendiente	Documentar procedimiento de preservacion de evidencia	P2	1 semana
H-29	NCm	5.30	RTO/RPO definidos sin prueba de validacion	Ejecutar prueba tecnica de recuperacion con medicion de tiempos	P1	2 semanas
H-30	NCm	5.34	Cifrado en reposo y politica	Implementar cifrado a nivel de campo en	P1	4 semanas

ID	Tipo	Area	Descripcion	Remediacion	Prioridad	Esfuerzo Est.
			de retencion de PII pendientes	RocksDB, documentar politica de retencion		
H-31	NCm	5.36	Auditoria interna de procesos (no tecnica) pendiente	Incluir en programa de auditoria interna	P2	2 semanas
H-32	NCm	5.37	Procedimientos operativos detallados en desarrollo	Completar documentacion de procedimientos operativos	P2	4 semanas
H-33	NCm	6.4	Sin politica disciplinaria para violaciones de seguridad	Elaborar politica con asesoria legal	P2	2 semanas
H-34	NCm	6.5	Sin procedimiento de desvinculacion para revocacion de accesos post-empleo	Elaborar procedimiento con checklist de revocacion	P1	1 semana
H-35	NCm	6.7	Politica de trabajo remoto pendiente	Formalizar politica de trabajo remoto con controles de seguridad	P2	1 semana
H-36	NCm	6.8	Canal formal de reporte de eventos de seguridad pendiente	Establecer canal dedicado con procedimiento de escalamiento	P2	1 semana
H-37	NCm	7.4	Controles de custodia de fragmentos M-of-N sin definir	Definir controles fisicos para custodia de fragmentos	P1	2 semanas
H-38	NCm	7.9	Custodia formal de fragmentos M-of-N pendiente	Designar custodios, firmar actas de custodia	P1	2 semanas
H-39	NCm	8.1	Politica de endpoints de administracion pendiente	Definir politica de hardening de equipos de administracion	P2	1 semana
H-40	NCm	8.6	Alertas automaticas de	Configurar alertas en	P2	1 semana

ID	Tipo	Area	Descripcion	Remediacion	Prioridad	Esfuerzo Est.
H-41	NCm	8.8	capacidad pendientes SLA de remediacion de vulnerabilidades sin definir	metricas de Fly.io Documentar SLAs: critica 24h, alta 7d, media 30d, baja 90d	P2	1 dia
H-42	NCm	8.11	Enmascaramiento sistematico de datos pendiente	Revisar todos los puntos de salida de datos para garantizar enmascaramiento	P2	2 semanas
H-43	NCm	8.12	Monitoreo de exfiltracion de datos pendiente	Implementar deteccion de transferencia anomala de datos	P2	4 semanas
H-44	NCm	8.16	Dashboards y alertas de monitoreo pendientes	Implementar dashboards operativos con alertas configuradas	P2	2-4 semanas
H-45	NCm	8.32	Change Advisory Board formal pendiente	Establecer CAB con procedimiento de revision de cambios	P2	2 semanas
H-46	NCm	Cl. 10	Proceso de no conformidad no probado (sin registros de NC)	Se activara al ejecutar H-02 (primera auditoria interna)	P2	0 (derivado)
H-47	OBS	Cl. 4	SGSI sin ciclo PDCA completo (Check/Act pendientes)	Completar primer ciclo con auditoria interna y revision por direccion	P2	Derivado
H-48	OBS	7.1-7.5	Controles fisicos delegados a Fly.io requieren verificacion de SOC 2 vigente	Obtener SOC 2 vigente	P2	1 semana
H-49	OBS	5.26	Procedimientos de respuesta a incidentes sin simulacro	Ejecutar tabletop exercise de respuesta a incidentes	P2	1 semana
H-50	OBS	8.5	Operadores sin MFA documentado (SSH con clave	Evaluar e implementar MFA para acceso SSH	P2	2 semanas

ID	Tipo	Area	Descripcion	Remediacion	Prioridad	Esfuerzo Est.
			publica pero sin segundo factor)			

8.2 Estadísticas

Tipo de Hallazgo	Cantidad
No Conformidad Mayor (NCM)	15
No Conformidad Menor (NCm)	31
Observacion (OBS)	4
Total hallazgos	50

8.3 Controles Conformes

De los 91 controles aplicables del SoA:

Resultado	Cantidad	Porcentaje
Conforme	33	36%
Observacion	9	10%
No Conformidad Menor	30	33%
No Conformidad Mayor	19	21%

Nivel de readiness global: 36% (conforme) + 10% (observacion) = 46%

Un auditor externo consideraria aceptable un nivel de 80%+ (conforme + observacion) para recomendar la acreditacion.

9. Plan de Remediacion Pre-Auditoria

9.1 Inmediato – Bloqueadores (antes de solicitar auditor)

Estos hallazgos impiden que un auditor externo emita un informe favorable. Deben resolverse antes de contratar la auditoria.

ID	Accion	Responsable	Plazo	Costo Est. (USD)
H-01	Firma de todos los documentos PS01-PS06 por Gerente General	Gerente General	1 semana	0
H-07	Elaborar y firmar NDAs con todo el	Oficial de Seguridad + Asesoría Legal	2 semanas	1,000-2,000

ID	Accion	Responsable	Plazo	Costo Est. (USD)
	personal y contratistas			
H-06	Anexos de seguridad en contratos laborales	Oficial de Seguridad + RRHH + Legal	2 semanas	1,000-2,000
H-04	Programa de concientizacion en seguridad: sesion inicial + material	Oficial de Seguridad	4 semanas	2,000-5,000
H-05	Verificacion de antecedentes del personal con acceso a claves	RRHH + Oficial de Seguridad	4 semanas	500-1,500
H-08	Preparar y ejecutar ceremonia de claves CA raiz	Oficial de Seguridad + Arquitecto + Testigo	6 semanas	3,000-5,000
H-13	Procedimiento de ceremonia de claves en area controlada	Oficial de Seguridad	2 semanas	500
H-09	Adquirir HSM FIPS 140-3 Nivel 2+ e integrar	Arquitecto + Oficial de Seguridad	12 semanas	15,000-40,000
H-10	Simulacro de continuidad (tabletop + prueba tecnica)	Oficial de Seguridad + Equipo Tecnico	3 semanas	1,000-3,000
H-03	Primera revision por la direccion con acta firmada	Gerente General + Oficial de Seguridad	1 semana	0
H-15	Implementar medicion de KPIs con registros historicos	Equipo Tecnico	4 semanas	2,000-5,000
H-02	Primera auditoria interna del SGSI	Auditor interno calificado (externo o interno)	4 semanas	5,000-10,000
H-11	Obtener y revisar SOC 2 de Fly.io	Oficial de Seguridad	2 semanas	0
H-12				1,000-2,000

ID	Accion	Responsable	Plazo	Costo Est. (USD)
	Negociar addendum de seguridad con Fly.io	Oficial de Seguridad + Legal	4 semanas	

Subtotal bloqueadores: USD 32,000-75,500

9.2 Corto Plazo (1-3 meses) – No Conformidades Menores

ID	Accion	Responsable	Plazo	Costo Est. (USD)
H-16	Implementar maker-checker en emision de certificados	Equipo Desarrollo	4 semanas	3,000-5,000
H-17	MFA para acceso administrativo	Equipo Tecnico	2 semanas	500-1,000
H-18	Contratar prueba de penetracion	Proveedor externo	4 semanas	8,000-20,000
H-29	Prueba tecnica de recuperacion con medicion de tiempos	Equipo Tecnico	2 semanas	1,000
H-30	Cifrado en reposo + politica de retencion PII	Equipo Desarrollo + Legal	4 semanas	3,000-5,000
H-34	Procedimiento de desvinculacion con checklist	RRHH + Oficial de Seguridad	1 semana	500
H-37	Controles de custodia de fragmentos M-of-N	Oficial de Seguridad	2 semanas	1,000-2,000
H-38	Designar custodios, firmar actas	Oficial de Seguridad + Custodios	2 semanas	500
H-19	Directorio de contactos de autoridades	Oficial de Seguridad	1 dia	0
H-20- H-28	Formalizacion de procesos menores (10 items)	Varios	4-8 semanas	2,000-5,000
		Equipo Tecnico		3,000-8,000

ID	Accion	Responsable	Plazo	Costo Est. (USD)
H-39- H-45	Controles tecnologicos menores (7 items)		4-8 semanas	

Subtotal corto plazo: USD 22,500-47,500

9.3 Mediano Plazo (3-6 meses) – Observaciones y Mejoras

ID	Accion	Responsable	Plazo	Costo Est. (USD)
H-47	Completar primer ciclo PDCA completo	Oficial de Seguridad	6 meses	0 (incluido en otras acciones)
H-48	Verificacion continua de SOC 2 de Fly.io	Oficial de Seguridad	Anual	0
H-49	Tabletop exercise de respuesta a incidentes	Oficial de Seguridad + Equipo	1 semana	1,000-2,000
H-50	MFA para acceso SSH	Equipo Tecnico	2 semanas	500-1,000
H-14	Contratar auditor externo calificado ISO 27001 para PS05	Gerente General	8-12 semanas	15,000-30,000

Subtotal mediano plazo: USD 16,500-33,000

9.4 Presupuesto Total Estimado

Fase	Rango (USD)
Inmediato (bloqueadores)	32,000-75,500
Corto plazo (NC menores)	22,500-47,500
Mediano plazo (observaciones + auditoria externa)	16,500-33,000
Total	71,000-156,000

El costo mayor es el HSM (USD 15,000-40,000) y la auditoria externa (USD 15,000-30,000). Si se opta por HSM basado en nube (AWS CloudHSM, Azure Dedicated HSM) el costo puede reducirse a USD 2,000-5,000/mes pero introduce dependencia de proveedor adicional.

10. Estimacion de Readiness

10.1 Readiness Actual por Area

Area	Readiness Actual	Observacion
Clausula 4 (Contexto)	85%	Bien documentado, falta evidencia de revision periodica
Clausula 5 (Liderazgo)	15%	Bloqueado por falta de aprobacion formal
Clausula 6 (Planificacion)	80%	Solido en papel, pendiente verificacion de ejecucion
Clausula 7 (Soporte)	20%	Sin concientizacion, sin formacion, sin comunicacion documentada
Clausula 8 (Operacion)	55%	Controles tecnologicos fuertes, procesos debiles
Clausula 9 (Evaluacion desempeno)	5%	Sin auditoria interna, sin revision por direccion, sin medicion de KPIs
Clausula 10 (Mejora)	10%	Proceso documentado, sin ejecucion
Controles organizacionales (5.x)	50%	15/37 implementados, brechas en proveedores y procesos
Controles de personas (6.x)	5%	0/8 implementados, brecha critica
Controles fisicos (7.x)	45%	Dependencia de proveedor cloud documentada parcialmente
Controles tecnologicos (8.x)	75%	21/32 implementados, fortaleza del SGSI

Readiness global promedio ponderado: ~35%

10.2 Readiness Proyectado Post-Remediacion

Asumiendo ejecucion completa del plan de remediacion (secciones 9.1 y 9.2):

Area	Readiness Actual	Readiness Proyectado	Delta
Clausula 4 (Contexto)	85%	95%	+10%
Clausula 5 (Liderazgo)	15%	90%	+75%

Area	Readiness Actual	Readiness Proyectado	Delta
Clausula 6 (Planificacion)	80%	90%	+10%
Clausula 7 (Soporte)	20%	80%	+60%
Clausula 8 (Operacion)	55%	85%	+30%
Clausula 9 (Evaluacion desempeno)	5%	75%	+70%
Clausula 10 (Mejora)	10%	70%	+60%
Controles de personas (6.x)	5%	70%	+65%
Controles tecnologicos (8.x)	75%	90%	+15%

Readiness proyectado post-remediacion: ~80-85%

10.3 Timeline Recomendado

Hito	Fecha Estimada	Prerequisitos
Firma de todos los documentos PS	2026-09-15	Revision final por Gerente General
NDA's y clausulas de empleo firmados	2026-10-01	Asesoria legal
Programa de concientizacion impartido	2026-10-31	Material desarrollado
Ceremonia de claves ejecutada	2026-11-15	Area controlada, testigos, procedimiento
Primera medicion de KPIs documentada	2026-11-30	Dashboards implementados
Simulacro de continuidad ejecutado	2026-11-30	PS03 aprobado
HSM adquirido e integrado	2026-12-31	Evaluacion de proveedores
Prueba de penetracion completada	2026-12-31	Contratacion de proveedor
Primera auditoria interna ejecutada	2027-01-31	Auditor interno calificado
	2027-02-15	Resultados de auditoria interna

Hito	Fecha Estimada	Prerequisitos
Primera revision por la direccion		
Acciones correctivas de auditoria interna cerradas	2027-03-31	Ejecucion de acciones
Solicitar auditoria externa (PS05)	2027-Q2	Todos los anteriores completados
Auditoria externa ejecutada	2027-Q2/Q3	Contratacion de auditor externo calificado
Presentacion de expediente a Entidad Acreditadora	2027-Q3	Informe de auditor favorable

Plazo realista para estar listo para la auditoria externa: 8-10 meses (Q2 2027).

11. Referencias

Referencia	Titulo
Ley 19.799 (2002)	Sobre documentos electronicos, firma electronica y servicios de certificacion
DS 181/2002	Reglamento de la Ley 19.799
EA-103 v2.1	Guia de acreditacion de prestadores de servicios de certificacion
ISO/IEC 27001:2022	Information security management systems – Requirements
ISO/IEC 27002:2022	Information security controls
ISO 19011:2018	Guidelines for auditing management systems
NIST SP 800-57 Parte 1 Rev. 5	Recommendation for Key Management
ETSI TS 102 042	Policy requirements for certification authorities issuing public key certificates
GOYA-PS01-001	Plan de Gestion de Riesgos y Amenazas

Referencia	Titulo
GOYA-PS02-001	Politica de Seguridad de la Informacion
GOYA-PS03-001	Plan de Continuidad del Negocio y Recuperacion de Desastres
GOYA-PS04-001	Plan del Sistema de Gestion de Seguridad de la Informacion
GOYA-PS06-001	Plan de Administracion de Llaves Criptograficas
GOYA-IRP-001	Plan de Respuesta a Incidentes (PS07)
CPS v1.0.0	Certification Practice Statement de Goya Ledger